О кибер-рисках

При работе с кибер-рисками возможны 2 варианта действий: 1) оставить риски у себя и снижать их своими силами; 2) передать риск третьим лицам за плату

Передача кибер-рисков: Страхование

1. Полис киберстрахования (Cyber Insurance)

Что покрывает:

– Расследование инцидентов и forensic-анализ
– Уведомление клиентов при утечке ПД (152-ФЗ)
– Восстановление данных и систем после атаки
– Перерыв в деятельности из-за кибератаки
– Вымогательство (ransomware)

Специфика для автодилера:

– Защита клиентских баз (паспорта, кредитные заявки)
– Риски компрометации DMS-систем
– Интеграции с банками и лизинговыми компаниями

Стоимость полиса:

8–15 млн руб/год при лимите 500 млн руб

Передача кибер-рисков: Аутсорсинг безопасности

2. MSSP-контракт (Managed Security Service Provider)

Передаваемые функции:

– SOC 24/7 (Security Operations Center)
– Управление уязвимостями
– Реагирование на инциденты

Стоимость: 18–36 млн руб/год

Провайдеры: BI.ZONE, Solar, Kaspersky MDR

Преимущества:

– Контрактная ответственность провайдера (SLA)
– Финансовые гарантии при нарушении SLA
– Доступ к экспертизе без содержания штата
– Снижение вероятности инцидента на 50–70%

Передача кибер-рисков

Итого затраты: 50 млн руб в год
Эффект: опустошительность 440 млн руб => 132 млн руб (так как не все риски покрываются страховым полисом), вероятность 0,7 => 0,25
Величина риска: 308 => 33
270>50 => эффективный набор мер

Собственные меры по снижению вероятности кибер -риска

1. Внедрение EDR/XDR + SOC-мониторинг

Что даёт:
– снижает вероятность успешной атаки (вирусы, вымогатели, проникновение в сеть) на 40–60%.
– раннее выявление аномалий, предотвращение шифрования данных.

Стоимость:
• EDR/XDR: 6–12 млн руб/год для компании масштаба Ключавто (1500–5000 ПК).
• SOC (аутсорс): 8–18 млн руб/год.

Итог: 14–30 млн руб/год.

2. Жёсткое разграничение доступов (IAM/Privileged Access Management)

Что даёт:
– снижает вероятность компрометации критичных систем (особенно BPM -систем).
– уменьшает масштаб атаки, если злоумышленник получил доступ одного сотрудника.

Стоимость:
• Внедрение IAM/PAM: 5 –15 млн разово + поддержка 2 –4 млн/год.

Итог: 14–30 млн руб/год.

Собственные меры по снижению вероятности кибер -риска

3. Регулярные пентесты и Red Team

Что даёт:
– позволяет закрыть уязвимости, которыми атакующие пользуются чаще всего.
– уменьшает вероятность успешной атаки на 15–25%.

Стоимость:
• Пентест инфраструктуры: 2 –5 млн руб/год
• Red Team (глубокое моделирование атаки): 3–7 млн руб/год.

Итог: 5–12 млн руб/год.

4. Двухфакторная аутентификация (MFA) везде

Что даёт:
– снижает вероятность взлома учёток примерно на 70 –90%.

Стоимость:
• Решения корпоративного MFA: 1 –3 млн руб/год.

Собственные меры по снижению вероятности кибер -риска

5. Обучение персонала (фишинг -симуляции + кибергигиена)

Что даёт:
– предотвращает до 30 –50% атак, связанных с фишингом.
– особенно актуально для дилерских центров (много входящих писем, работа с клиентами).

Стоимость:
• Корпоративное обучение + симуляции: 1 –2 млн руб/год.

Компании, предоставляющие решения в этой сфере: Cofense Phishme, KnowBe4, Barracuda Phishline

Собственные меры по снижению опустошительности кибер -риска

6. Резервное копирование с изоляцией (air-gapped backups)

Что даёт:
– при атаке типа ransomware не придётся полностью восстанавливать инфраструктуру.
– уменьшает ущерб восстановления ИТ с 30 – 80 млн руб → до 10–25 млн руб.

Стоимость:
• Организация защищённого резервирования: 5–12 млн руб разово +1–3 млн руб/ год.

Решения на рынке: Кибер Бэкап, Handy Backup

7. Disaster Recovery Plan (DRP) + горячая площадка

Что даёт:
– снижает потери сервиса 50–120 млн руб→ 10–30 млн руб при инциденте.

Стоимость:
• DR-сайт в аренде: 8–20 млн руб/ год
• DRP-документация и тестирование: 1–3 млн руб/ год.

Собственные меры по снижению опустошительности кибер -риска

8. Сегментация сети и контейнеризация критичных сервисов

Что даёт:
– при взломе дилерские центры не «падают цепочкой».
– снижает масштабы сбоя, уменьшает репутационный ущерб.

Стоимость:
• Сегментация сети: 3–8 млн руб разово.
• Контейнеризация: 2 –5 млн руб разово.

9. DDoS-защита (особенно для гос/корп клиентов)

Что даёт:
– прямое сокращение финансового ущерба (страховщик покрывает часть убытка).
– снижает опустошительность 440 млн → примерно 200–280 млн в худшем сценарии.

Стоимость:
• Полис 150–300 млн покрытия: 4–10 млн руб/ год.

Собственные меры по смягчению кибер -риска

Итоговая величина расходов= 113 млн руб в год + 24 млн руб разово

Итоговая вероятностная оценка:
0,7 → ~0,25 (реалистично для защищённой компании).

Итоговая новая опустошительность:
440 млн → 160 млн

Новый риск по верхним границам:
При вероятности 0,25 и опустошительности 160 млн
EMV риска = 0,25 * 160 = 40